🌐 Module 05: Web Application Penetration Testing

```
# Exercise 8: Directory Browsing a WordPress Website using DirBuster and Accessing Shell
```

Scenario

This lab is a continuation of **Exercise 05.7**. In the previous lab exercise, you learned how to edit theme files and upload a custom PHP command shell. A penetration tester needs to determine the directory structure of a web application to find hidden or accessible sensitive folders and files.

In this lab, you will learn how to perform automated directory browsing using DirBuster to discover the uploaded shell location (`404.php`), access it via a web browser, and execute system-level commands to gain remote access to the host server.

Objective

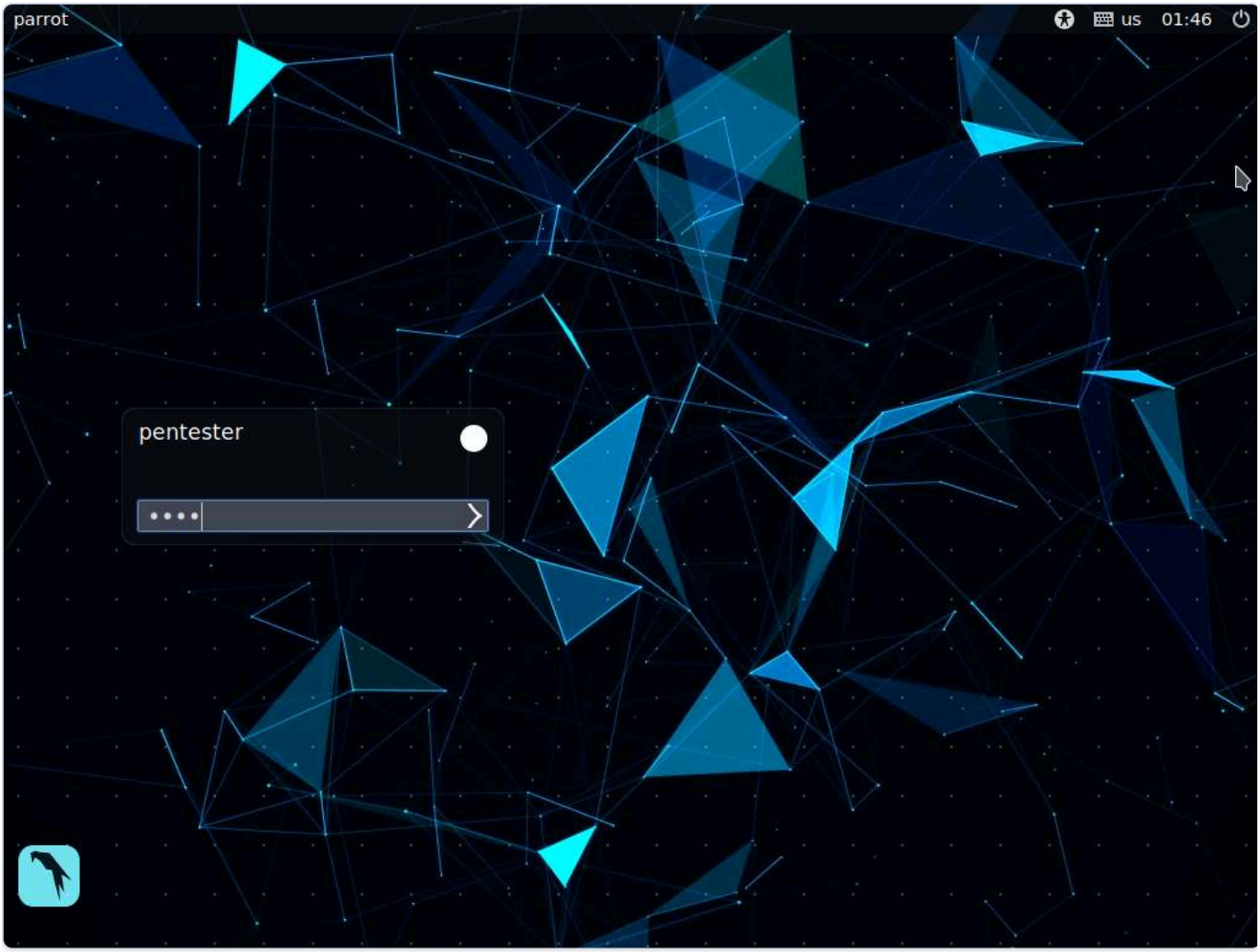
The objective of this lab is to help students learn how to:
- Use DirBuster to perform directory and file brute-forcing on web applications
- Locate uploaded web shells within theme directories (`/wp-content/themes/twentyfifteen/404.php`)
- Execute remote system commands via HTTP GET parameters to verify Remote Code Execution (RCE)

Task 1: Directory Browsing a WordPress Website using DirBuster and Accessing Shell

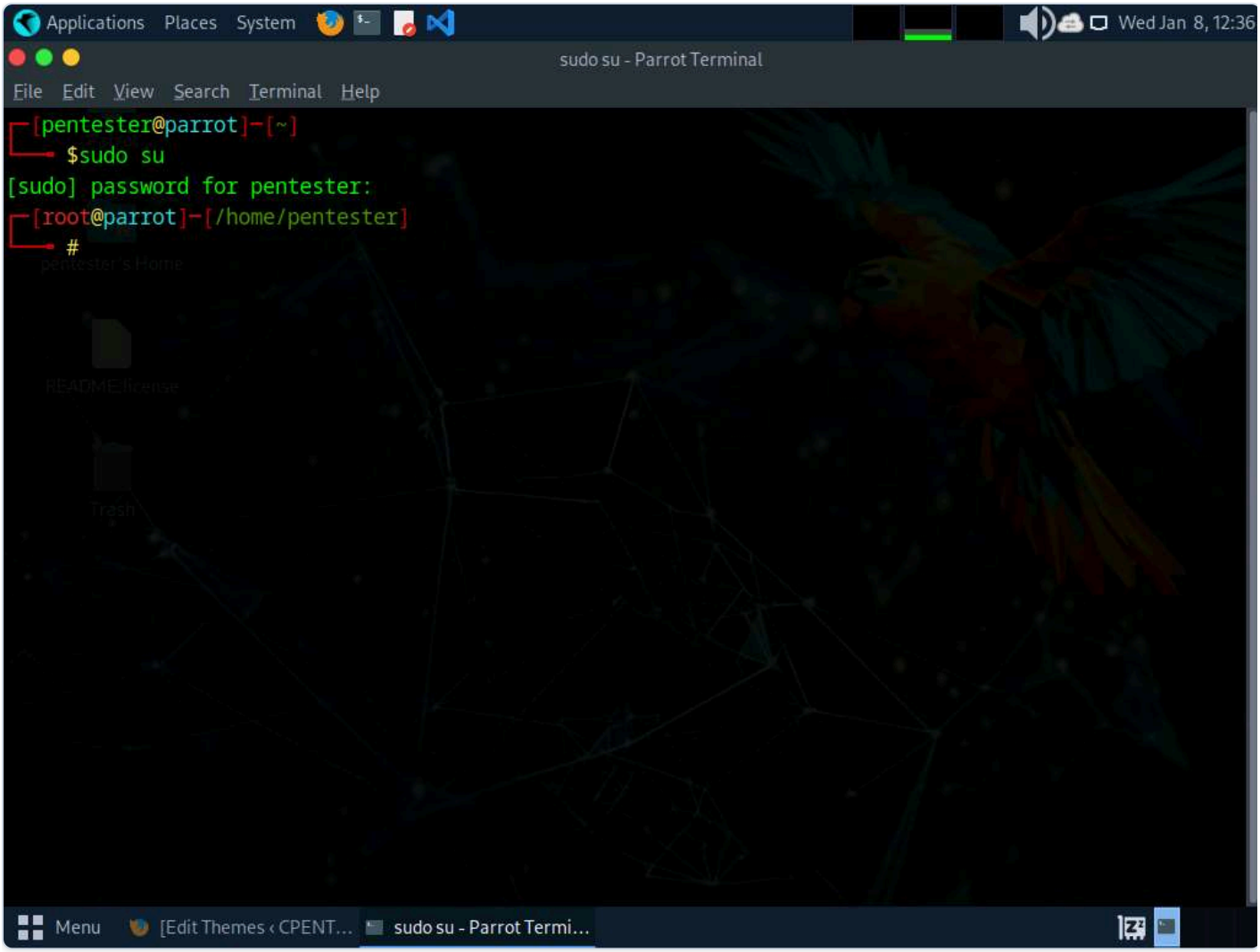
In this task, we launch DirBuster against `http://www.cpent.com`, brute-force web directories to locate the `TwentyFifteen` theme directory, and access `404.php?cmd=whoami` to obtain the current user context from the target server.

Lab Tasks

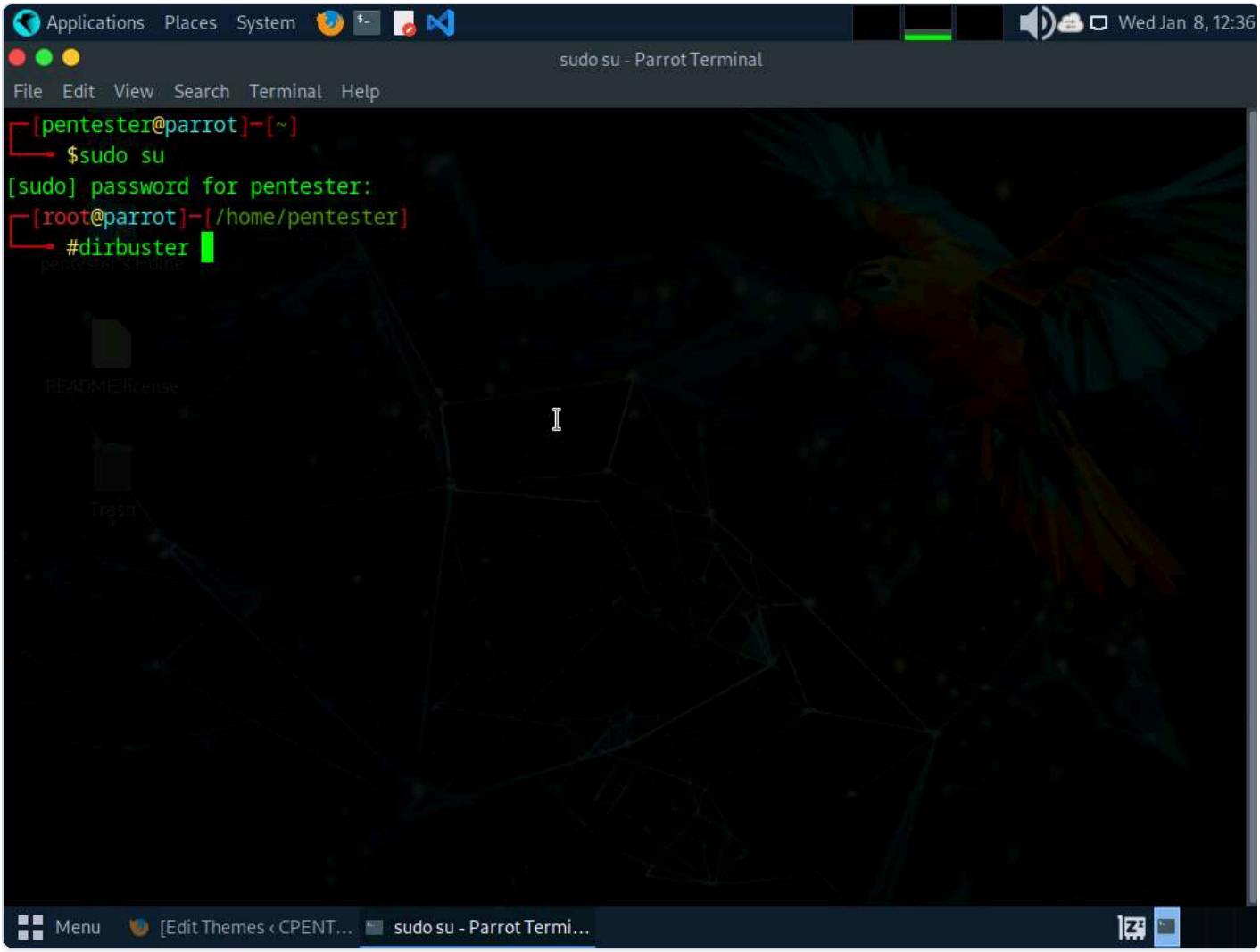
1. Click **Parrot Security**. Type **toor** in the Password field and press Enter.
2. *(If you are already logged in, skip to step 2.)*



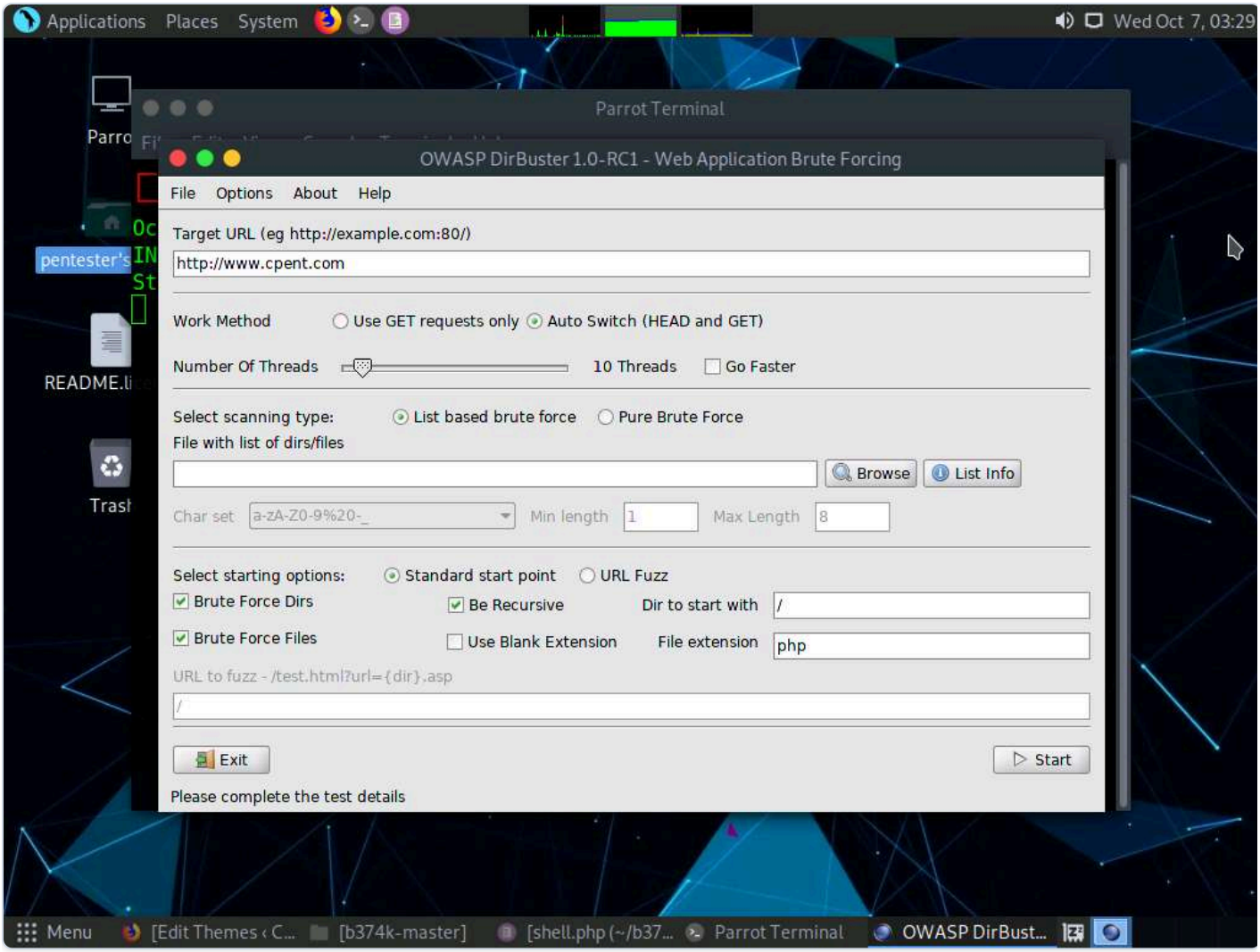
1. Launch a command-line terminal, type **sudo su** and press Enter. Enter **toor** as the password.



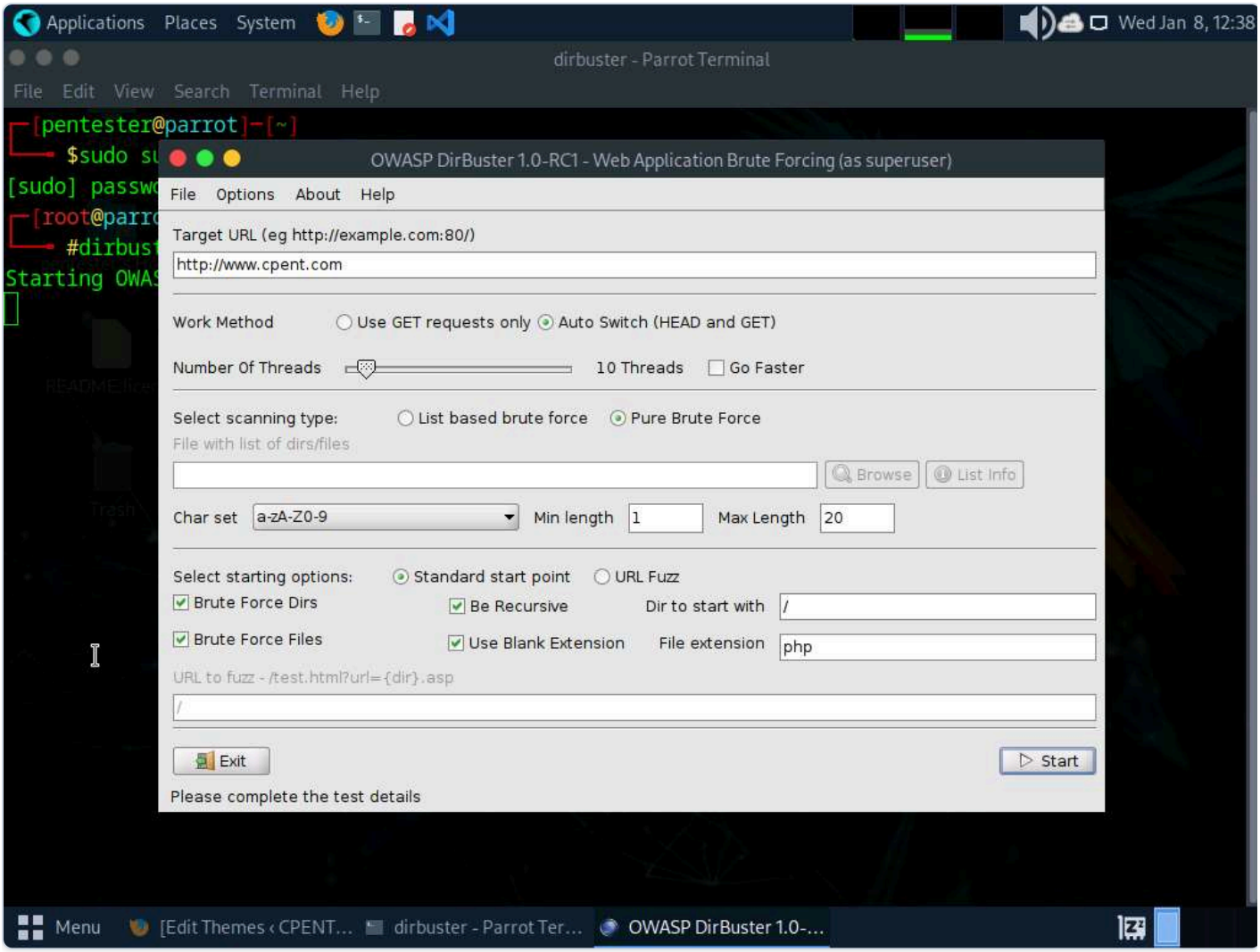
1. Type **dirbuster** and press Enter to launch the graphical interface.



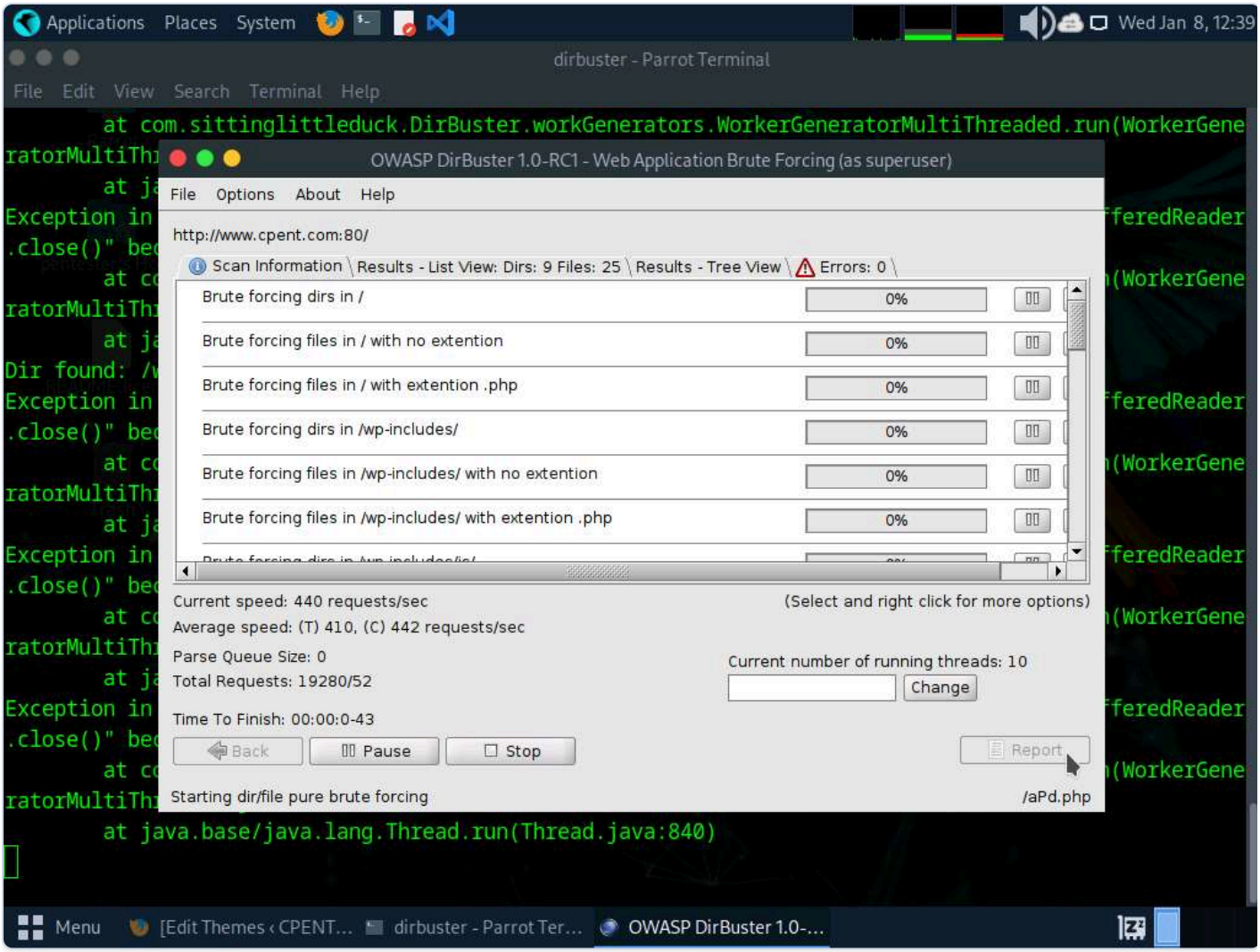
1. In the DirBuster main window, type **http://www.cpent.com** in the **Target URL** field.



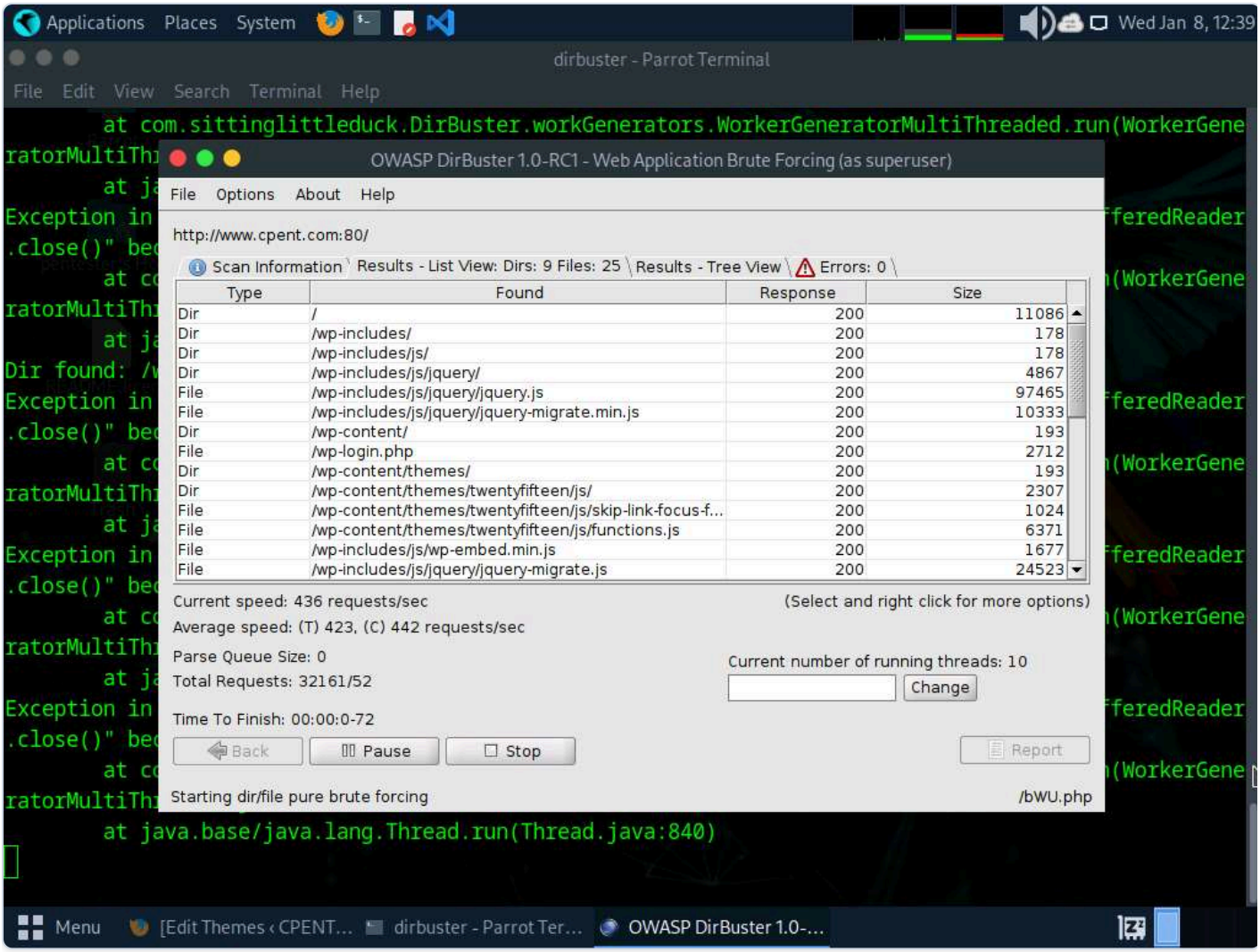
1. Configure scan settings:
2. Select **Pure Brute Force** radio button in the **Select scanning type** section
3. Select **a-z0-9** from the **Char set** drop-down list
4. Set **Min Length** to **1** and **Max Length** to **20**
5. Check **Use Blank Extension** option
6. Click **Start** to initiate directory brute-forcing.



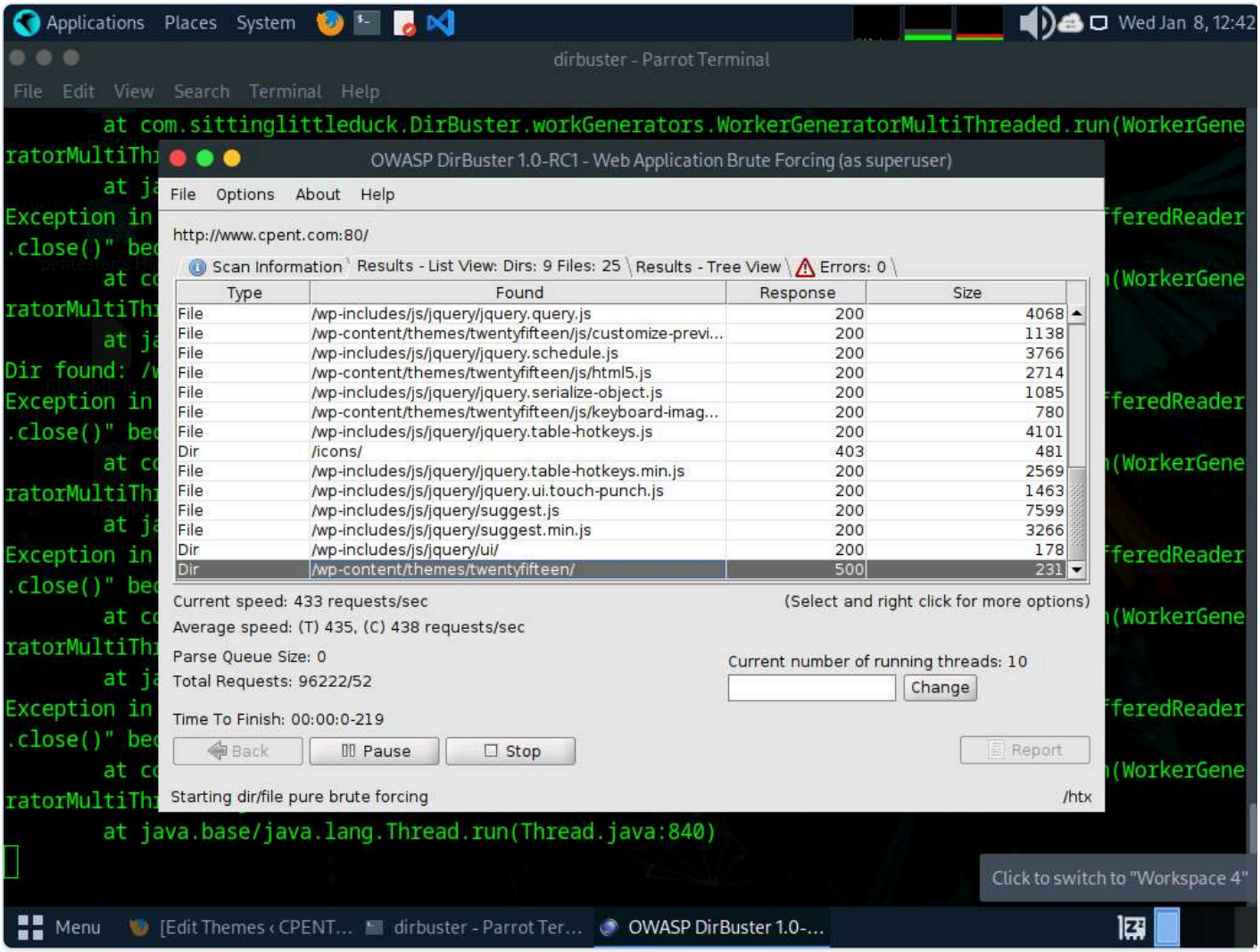
1. DirBuster begins brute forcing directories and files, displaying status in the **Scan Information** tab.



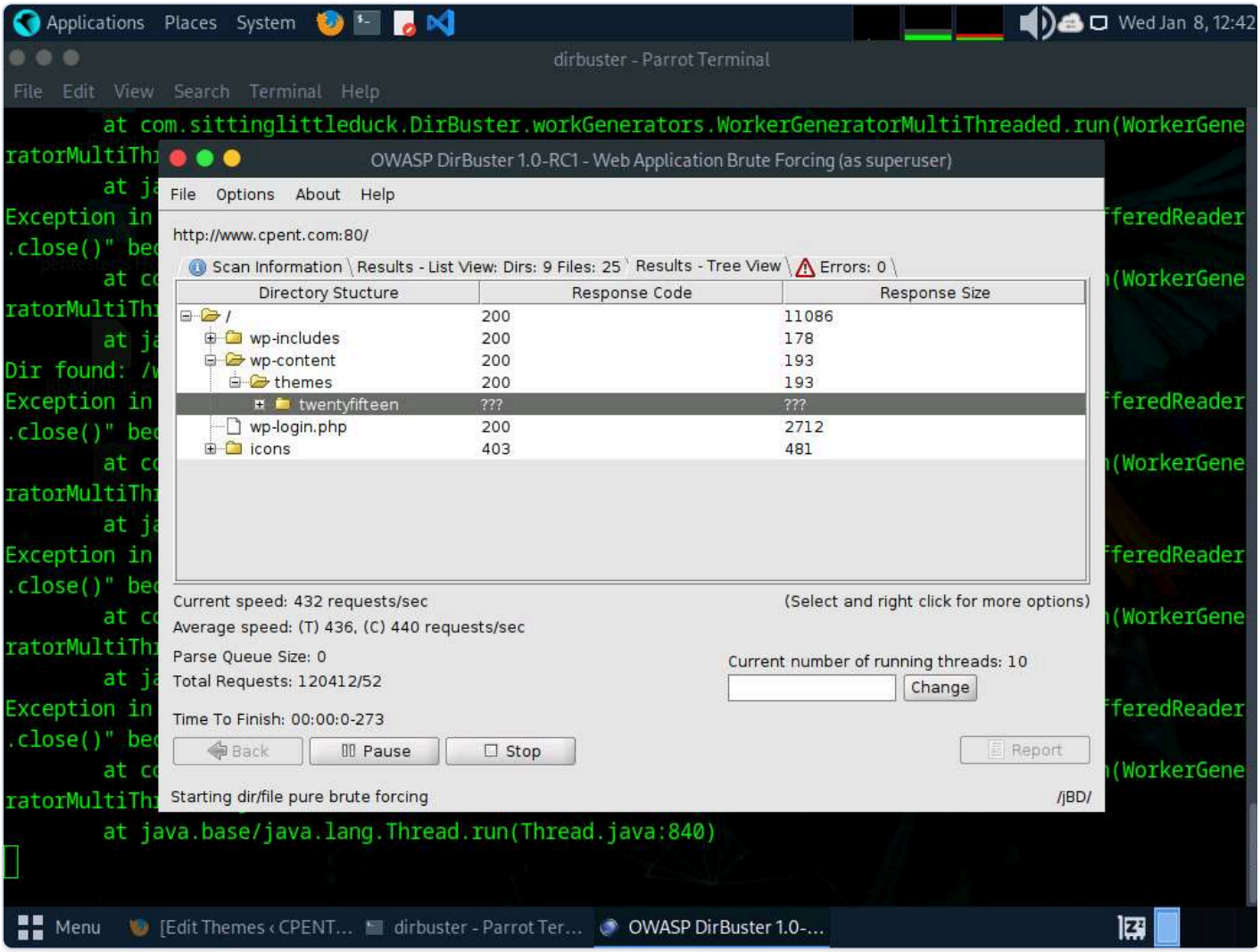
1. Click the **Results - List View** tab to monitor discovered files and directories.



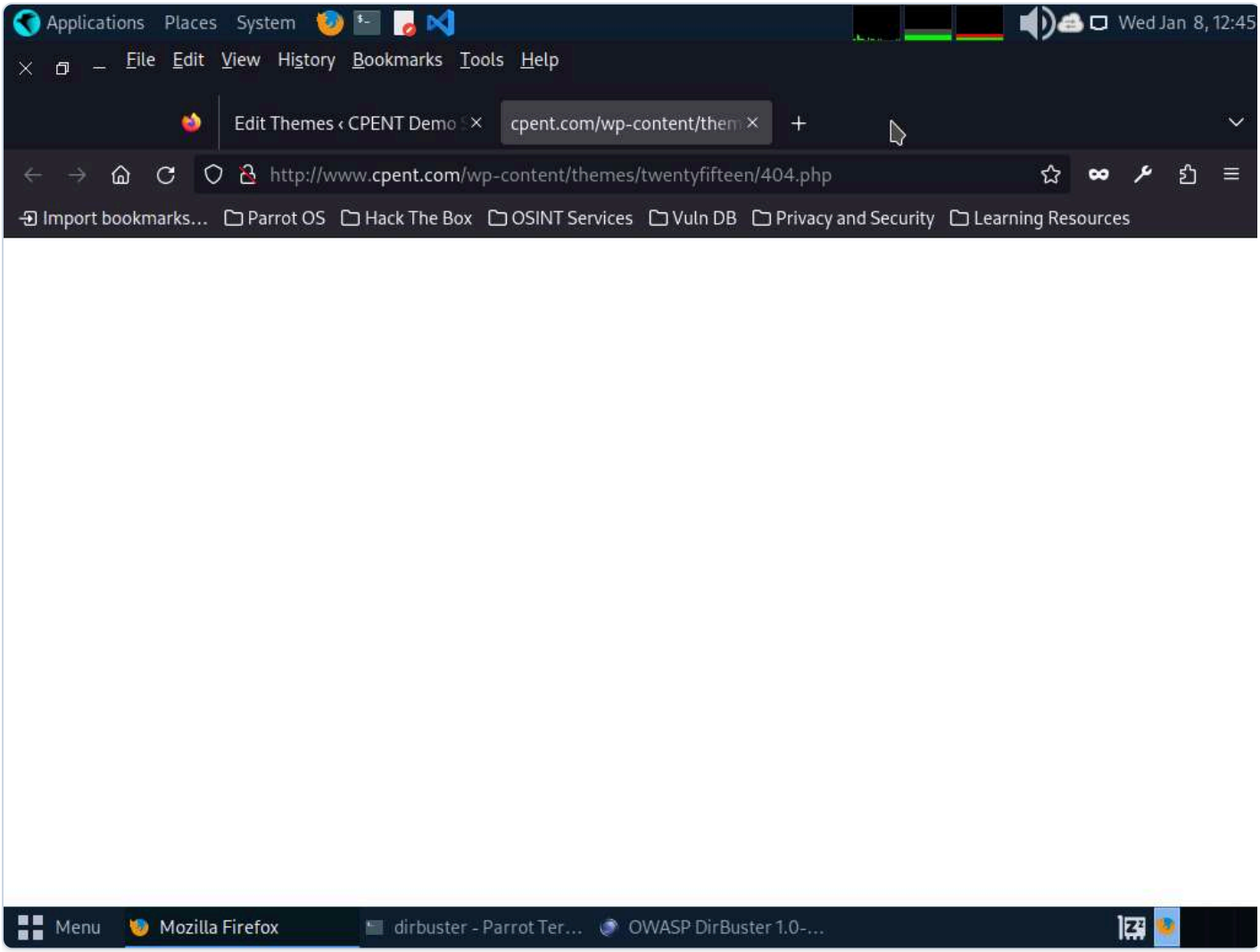
1. Scroll through the **Results - List View** tab to identify the theme directory **twentyfifteen**.



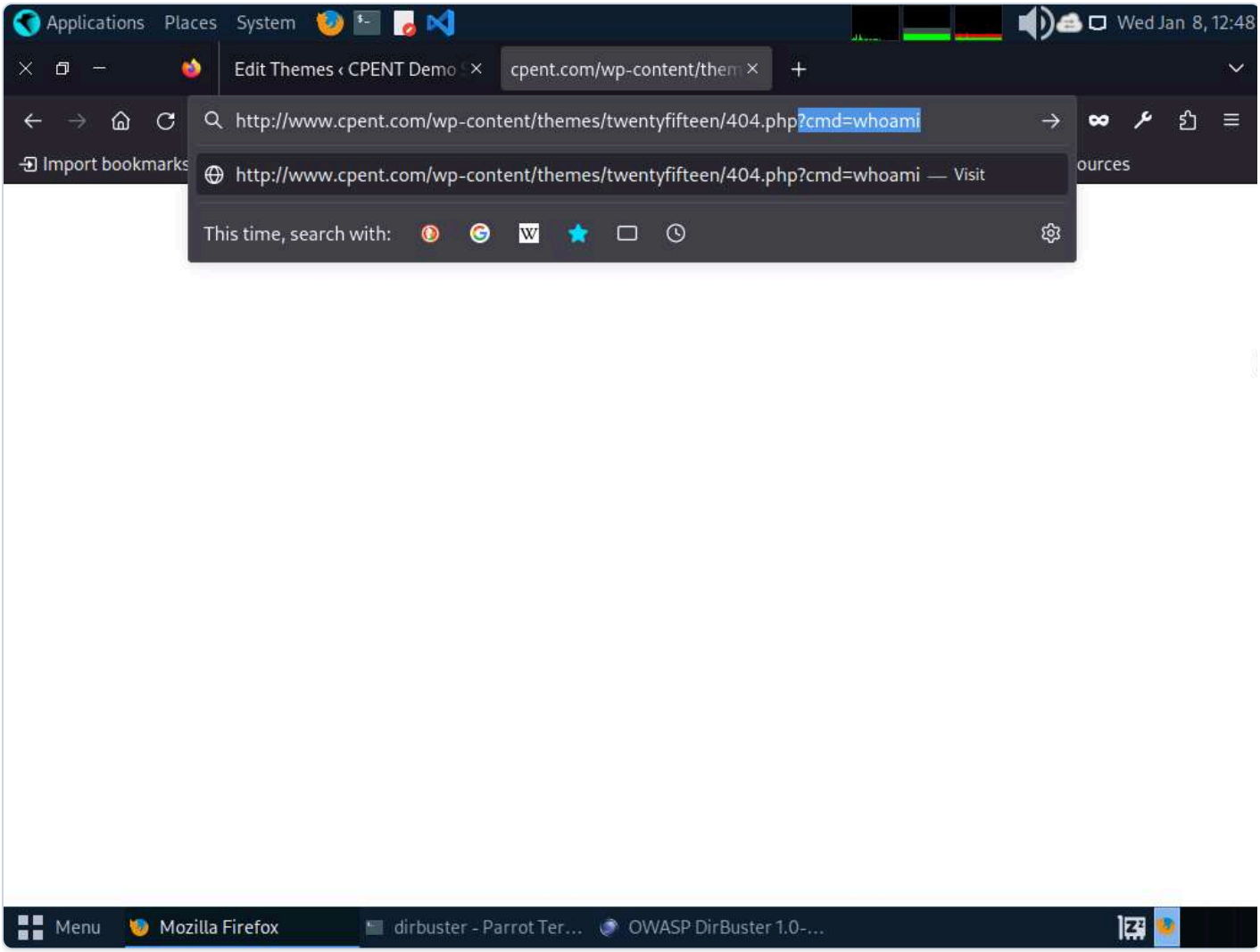
1. Click the **Results - Tree View** tab to examine the full directory path structure. The path to the TwentyFifteen theme is identified as:
   /wp-content/themes/twentyfifteen/



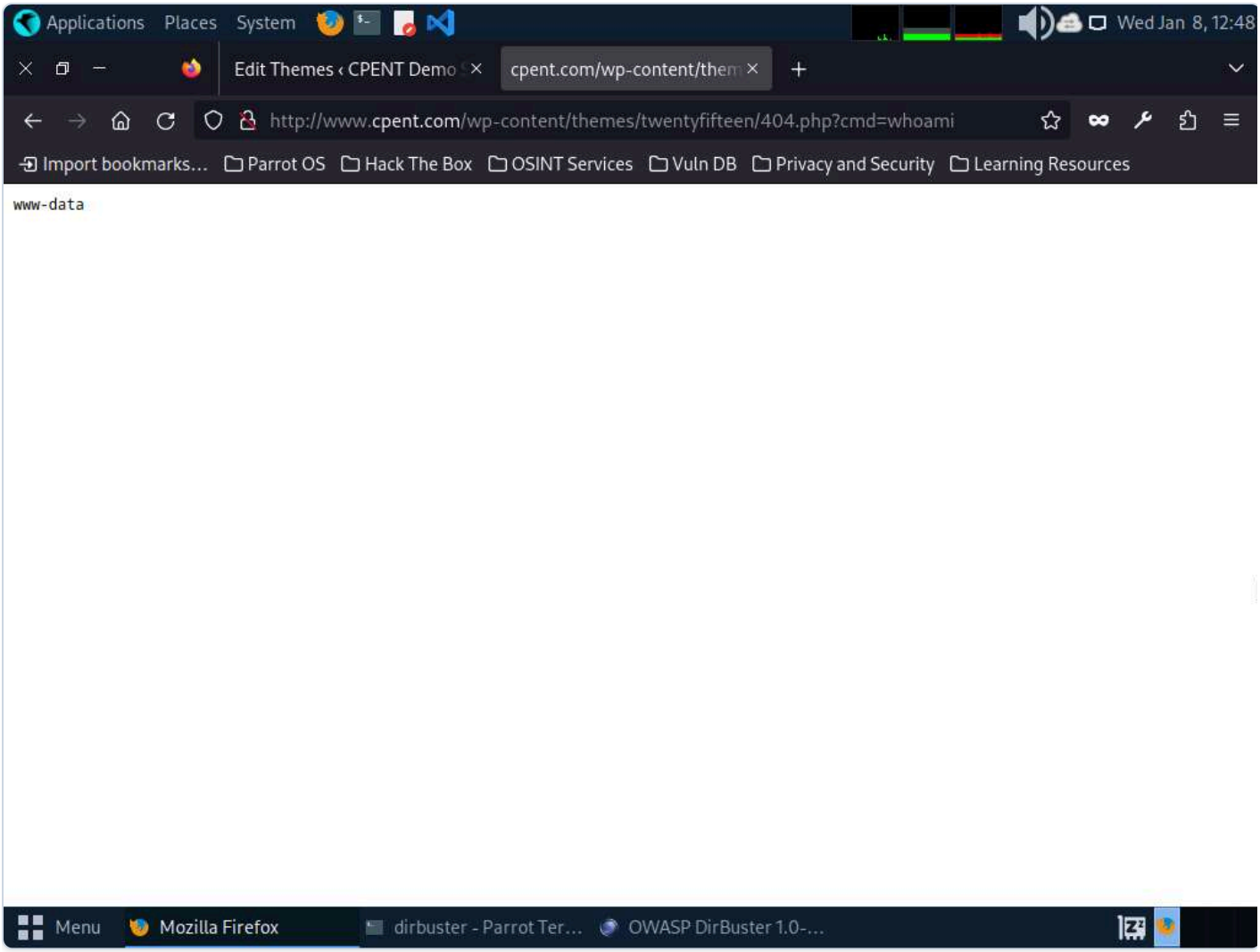
1. Open Firefox web browser and navigate to:
   http://www.cpent.com/wp-content/themes/twentyfifteen/404.php



1. Test remote command execution by appending the `cmd` GET parameter to the URL: **http://www.cpent.com/wp-content/themes/twentyfifteen/404.php?cmd=whoami**



1. Press Enter and observe the output returned by the web shell: **www-data**.



1. This confirms successful Remote Code Execution via the uploaded PHP shell. Close all open windows.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.8.1.1** On the Parrot Security machine, develop a tailored PHP shell and determine the entry point to access the server hosting the WordPress web application at `http://www.cpent.com/wp-login.php`. Log in using the provided credentials (`mike`/`prince`). Modify the WordPress theme file `404.php` to deploy the PHP shell. Utilize the DirBuster tool to locate the uploaded shell and establish server access. Enter the output returned after appending `whoami` command. [!SUCCESS] ✅ **Answer:** **www-data**